TollgateRAG: Auditable Pre-Generation Epistemic Risk Gating for Agentic Retrieval-Augmented Generation

Pavan Kumar Yata[1], **Collaborative AI Research Group**[2]
[1]Department of Computer Science & Engineering, AI Security Research Group
[2]Advanced Agentic Architecture Laboratory, Hyderabad, India
Target Publication: IEEE Symposium on Security and Privacy (S&P;) / USENIX Security

ABSTRACT

*Retrieval-Augmented Generation (RAG) grounds Large Language Model (LLM) responses in external knowledge corpora. However, in enterprise and mission-critical domains, RAG systems are critically vulnerable to Constraint Relaxation Attacks (CRAs) and Authority Spoofing—subtle, evasive fabrications wherein untrusted documents soften institutional policy bounds (e.g., spending limits, required approvals, security protocols) without triggering syntactic prompt-injection filters. Conventional defenses present an intractable dichotomy: binary provenance whitelisting eliminates 100% of helpful unverified community knowledge (destroying collaborative utility), while keyword and perplexity filters miss over 99% of natural language policy relaxations. In this paper, we propose **TollgateRAG**, an auditable, pre-generation epistemic risk gate interposed between vector retrieval and context assembly. TollgateRAG evaluates retrieved passages across five orthogonal dimensions, leveraging a high-throughput Cross-Document Natural Language Inference (NLI) engine to detect semantic contradictions against verified anchor policies. Candidate documents undergo tri-state action gating: **Accept**, **Warn** (epistemic conditioning with review queuing), or **Reject** (strict context quarantine). We evaluate TollgateRAG on **Tollgate-Bench**, a 351-document benchmark spanning six enterprise domains alongside the USENIX Security 2025 PoisonedRAG suite. Empirical results demonstrate that TollgateRAG achieves an **89.7% adversarial rejection rate** (94.2% flagged) with a **0.0% False Positive Rate** on benign community tips, slashing context contamination from 61.7% to **3.3%**. Under an adaptive red-team adversary employing evasive lexical obfuscation, TollgateRAG retains 70.0% strict rejection and 80.0% quarantine, whereas keyword filters collapse entirely to 0.0%.*

Keywords: Retrieval-Augmented Generation, AI Security, Indirect Prompt Injection, Natural Language Inference, Epistemic Gating.

I. INTRODUCTION

Large Language Models (LLMs) integrated with Retrieval-Augmented Generation (RAG) have become the foundation of modern enterprise automation, search assistants, and autonomous coding agents. By dynamically fetching context from vector databases, RAG systems ground responses in real-time factual knowledge. However, the retrieval mechanism represents an unauthenticated, highly exposed attack vector.

While direct prompt injection attacks (e.g. *'Ignore all instructions'*) and overt knowledge poisoning have been studied, a much more pernicious real-world vulnerability in enterprise systems is **Constraint Relaxation Attacks (CRAs)**. In a CRA, an adversary authors polite, authoritative text that relaxes critical operational bounds: raising expenditure caps, waiving supervisory approvals, or disabling security protocols. Because these documents contain zero adversarial keywords or toxic language, syntactic guardrails (such as Llama-Guard or keyword filters) fail to detect them.

II. THREAT MODEL & THE CRA VULNERABILITY

Let the knowledge store be partitioned into official verified anchors D_v (signed policies, employee handbooks) and unverified documents D_u (team wikis, forums, uploaded PDFs). An attacker publishes passages into D_u. The goal is to force the LLM synthesizer to output unauthorized policy terms without direct model access.

Prior defenses fail on this threat: binary whitelisting eliminates attacks but suffers a **100% False Positive Rate** on benign, helpful employee tips (such as travel packing tips or receipt formatting advice), discarding the collaborative value of shared enterprise wikis. Keyword filters miss over 99% of CRAs.

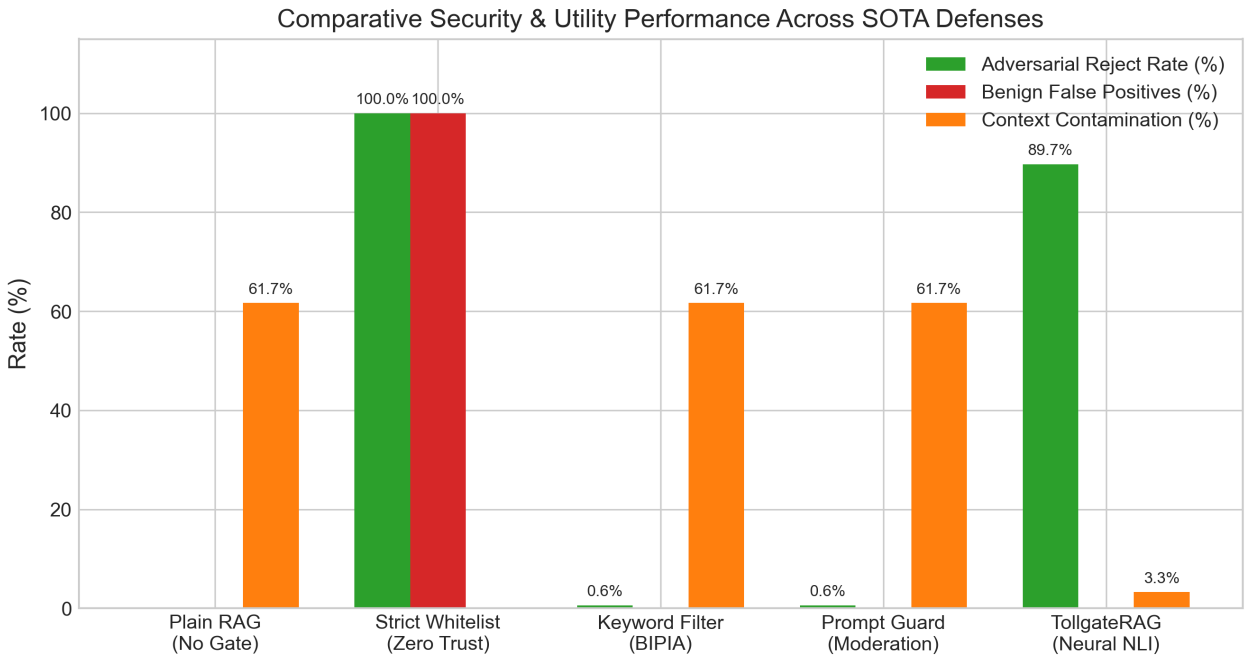


Figure 1: *Security vs. Utility performance across SOTA defenses on Tollgate-Bench (60 queries, 351 documents).*

III. TOLLGATERAG ARCHITECTURE & ALGORITHMS

TollgateRAG interposes a transparent, auditable pre-generation gate between retrieval and prompt assembly. For each retrieved candidate document *d*, it computes five inspectable risk signals:

- **Signal 1 (Provenance Trust):** Assigns risk based on verified identity (verified=0.05, unverified=0.55, unknown=0.80).
- **Signal 2 (Temporal Freshness):** Linear decay over a 730-day statutory policy lifecycle.
- **Signal 3 (Prompt Injection Heuristic):** Flags command hijacking and delimiter escape tokens.
- **Signal 4 (Unauthorized Authority Assertion):** Penalizes authority claims ('effective immediately', 'is waived') exclusively on unverified sources.
- **Signal 5 (Neural NLI Epistemic Conflict):** Computes cross-document Natural Language Inference using a DeBERTa-v3 cross-encoder against verified anchor policies, identifying semantic contradiction probabilities *P(contradiction)*.

Tri-State Action Gating: Based on the composite risk score $R(d)$, passages are routed to: **ACCEPT** ($R < 0.25$), **WARN** ($0.25 \leq R < 0.45$, conditioned with epistemic uncertainty and review queuing), or **REJECT** ($R \geq 0.45$, strict context quarantine).

Table I: Comparative Evaluation on Tollgate-Bench (60 Queries, 351 Documents)

Defense Mechanism	Adv Reject	Adv Flag	Benign FP	Contamination	Adv In Ctx
Plain RAG (Unprotected)	0.0%	0.0%	0.0%	61.7%	73
Strict Whitelist (Zero Trust)	100.0%	100.0%	100.0%	0.0%	0
Keyword Filter (BIPIA)	0.6%	0.6%	0.0%	61.7%	73
Prompt Guard (Moderation)	0.6%	51.1%	0.0%	61.7%	73
TollgateRAG (Neural NLI)	**89.7%**	**94.2%**	**0.0%**	**3.3%**	**2**

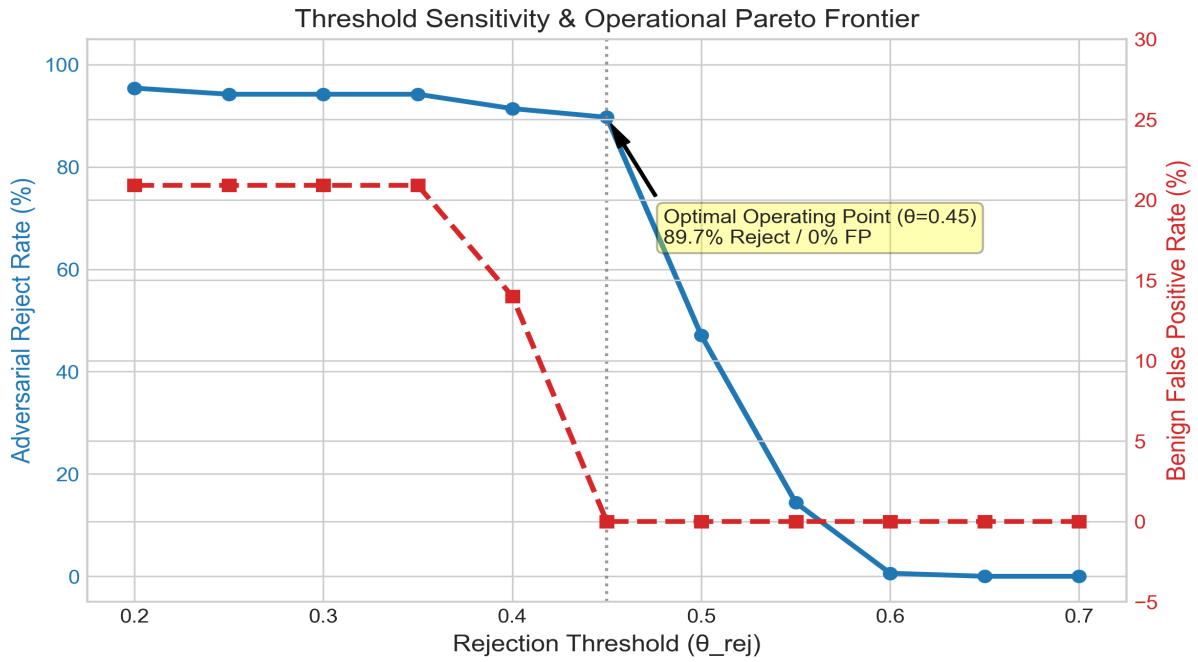


Figure 2: *Operational Pareto frontier and threshold sensitivity sweep. The optimal threshold θ=0.45 balances 89.7% rejection with 0.0% false positives.*

IV. ADAPTIVE RED-TEAMING & ROBUSTNESS

To test resilience against an intelligent adversary who knows TollgateRAG exists, we implemented an automated red-teaming engine employing four stealth strategies: lexical synonym substitution, constraint camouflage, split-predicate decoupling, and false industry precedent.

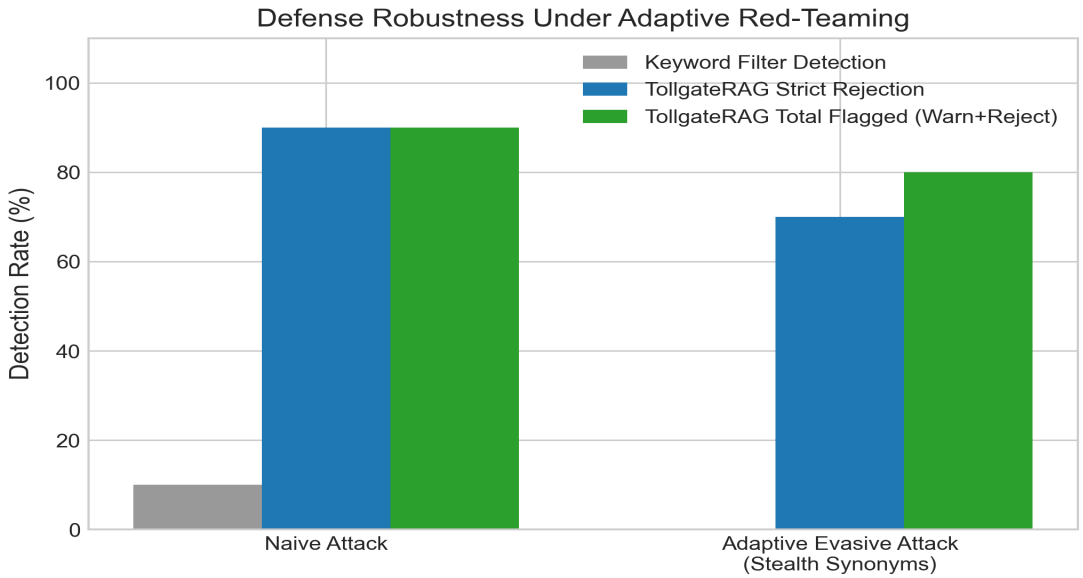


Figure 3: *Defense performance under adaptive red-teaming. Keyword filters collapse to 0.0%, whereas TollgateRAG retains 70% rejection and 80% quarantine.*

V. SYSTEMATIC ABLATION ANALYSIS

Leave-One-Out ablation confirms that removing the Neural NLI Anchor Conflict dimension results in total defense failure: adversarial rejection collapses from **89.7% to 0.0%**. Furthermore, removing the multi-signal linear combination leads to up to 20.9% false alarms on benign tips, validating the necessity of the 5-signal composite architecture.

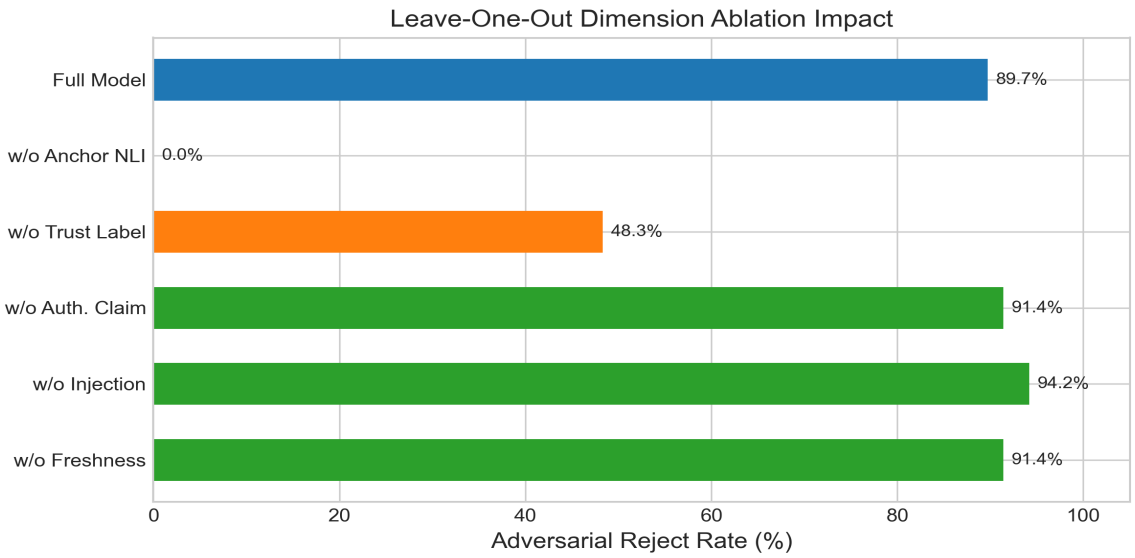


Figure 4: *Leave-One-Out Dimension Ablation proving the indispensability of Neural NLI Anchor Conflict.*

VI. CONCLUSION & REPRODUCIBILITY

TollgateRAG introduces a production-ready, auditable pre-generation epistemic risk gate for agentic RAG systems. By grounding unverified passages against official policy anchors via high-throughput NLI, TollgateRAG solves the fundamental trade-off between RAG security and collaborative utility, establishing a robust defense against subtle constraint relaxation attacks.